

PRD: Non-Human Identity Risk Quantification

Securing the Unmanaged Frontier Within Qualys ETM Identity

Team	Identity Security Platform (ETM Identity)
Contributors	Kushal Zambare (Product Manager)
Status	In Development
Target Launch	Q3 2026 (v0 — Discovery & Inventory)
Resources	Based on public Qualys ETM Identity materials, Oct 2025 ROCon Houston

Portfolio Disclaimer: This PRD is written by Kushal Zambare based solely on public Qualys ETM Identity materials. It is not affiliated with or endorsed by Qualys, Inc. All sizing numbers are illustrative assumptions, not internal Qualys data.

1. Problem Definition

Enterprises run IAM, IGA, PAM, and ITDR tools, yet identity-driven breaches persist and remain among the most expensive to resolve.

The root cause is a category of identity that none of these tools were designed for: **Non-Human Identities (NHIs)** — service accounts, machine identities, API keys, workload identities, and agentic-AI agents. They outnumber human identities roughly 50:1, rarely support MFA, rotate slowly or never, and typically have no clear owner.

Security teams cannot answer the three questions that determine response:

- Which NHIs are dangerous?**
- Who owns them?**
- What breaks if we shut them off?**

Core insight: The problem is not a lack of tools — it is the lack of a unified risk language and a closed remediation loop for NHIs. Existing tools govern who *should* have access; none quantify which identities are actually exploitable, or map the attack path from a compromised identity to crown-jewel assets.

2. Goals

Reduce enterprise identity-driven breach risk by quantifying NHI exposure, attributing ownership, and surfacing actionable attack paths — all within the existing Qualys TruRisk™ language and ROC workflow.

By improving the **quality** of NHI risk remediation (exploitability, blast radius, recency), the goals are to:

- Increase **% of NHIs with attributed owners** — target ≥60% attributed at ≥70% confidence within 6 months of v1 GA, with a defined triage path for the remainder
- Increase **NHI discovery coverage** — target ≥95% enumeration across *connected* identity sources within one scan cycle
- Reduce **open toxic attack paths** to Tier-0 / crown-jewel assets, QoQ
- Reduce **Mean Time To Remediate (MTTR)** a flagged NHI, from weeks to days

3. Business - Product Outcome Mapping

Business Outcome	Platform Metric	Product Outcome (Focus)	Why This Outcome
↑ TruRisk Score Improvement (Customer)	↓ Aggregate NHI Identity TruRisk Score QoQ	↓ # toxic attack paths to Tier-0	Direct proxy for exploitable identity exposure
↑ ARR / Renewal Rate	↑ ROC Analyst weekly active users on NHI worklist	↑ % NHIs with attributed owner	Drives adoption — unattributed means unactioned
↑ Platform Stickiness	↑ % of recommendations converted to ITSM tickets	↑ NHI discovery coverage (≥95% of connected sources)	Coverage gaps = blind spots = breach risk
↓ Breach Cost for Customers	↓ MTTR on flagged NHI (weeks → days)	↓ MTTR on flagged NHI	Measurable risk reduction in the customer environment
↑ Product Differentiation	Unified Vuln + Asset + Identity score	Unique to Qualys	No IGA/PAM/ITDR competitor produces a unified score across all three surfaces

4. Success Metrics

Metric	Type	Priority	Why It Matters
↓ Aggregate NHI Identity TruRisk Score (QoQ)	North Star	Focus	Proves exploitable identity exposure is actually reducing — not just more tickets being closed
↓ # open toxic attack paths to Tier-0	Functional	L1	Direct measure of blast-radius exposure

assets			— the thing that causes breaches
↑ NHI discovery coverage (% of connected sources)	Functional	L1	Coverage below 95% means blind spots — unmanaged NHIs that could be exploited
↑ % high-risk NHIs with attributed owner	Functional	L1	Unattributed = unactioned. Owner attribution is the prerequisite for any remediation. Scoped to high-risk because that is the decision-relevant slice
↓ MTTR on a flagged NHI (target: days, not weeks)	Functional	L1	Speed of remediation is the clearest signal the closed loop is working
↑ % recommendations converted to ITSM tickets	Functional	L1	Measures workflow adoption — are analysts using the ROC-to-ITSM loop or ignoring it?
↑ Pass rate on TruConfirm re-validation	Functional	L2	Confirms risk actually dropped — not just that a ticket was closed. Guards against false closure
↑ Weekly active ROC analysts on NHI worklist	Functional	L2	Platform stickiness and adoption signal
Ticket abandonment rate (ITSM tickets not actioned within 30 days)	Failure	Failure	If tickets are generated but not actioned, the loop is broken. Sustained rate >40% triggers a PM-led redesign review of the ticket payload
Scan performance impact on identity sources	Non-Functional	L3	Discovery must not degrade IdP performance — a deal-breaker with enterprise customers
Attack-path graph computation latency at 50k NHI scale	Non-Functional	L3	Graph latency above threshold makes the worklist unusable in a live incident
Discovery agent crash rate	Non-Functional	L3	Agent stability is critical for continuous discovery

Only the functional metrics above are directly controlled by the Identity Platform team. Non-functional metrics are monitored by Platform Engineering. Failure metrics trigger a rollback review.

Known measurement caveat: discovery coverage is measured against *connected* identity sources. The true NHI population of an enterprise is unknown by definition — that is the problem being solved. The UI must never imply absolute coverage.

5. Non-Goals

The following are explicitly excluded from this PRD's scope:

- **Identity Governance & Administration (IGA) / Provisioning.** We consume IGA data as a signal source (SailPoint, Saviynt). We do not provision, deprovision, or manage access lifecycle. That is a separate product category.
- **PAM / Secrets Vault.** We read risk signals from CyberArk, Delinea, and HashiCorp Vault. We do not store, rotate, or distribute secrets in v1-v2.
- **Human Identity Risk Management.** ETM Identity already covers human identity risk. This PRD's scope is NHI-specific: service accounts, machine identities, API keys, workload identities, agentic-AI agents.
- **Automated Credential Rotation (v1-v2).** Recommend-and-ticket only in v1-v2. In-platform orchestrated rotation is explicitly v3 scope.
- **Inline enforcement / blocking.** ETM Identity does not block authentication in real time. That is Silverfort's category and would require an inline proxy architecture we deliberately avoid.

Excluded metrics: breach-cost attribution, NPS, and IGA certification completion rates — all outside the identity platform team's direct control.

6. User Segmentation

ROC Analysts and IAM Administrators respond to identity risk daily, are highly motivated, and sit closest to the north-star metric. They are the easiest segment to influence first.

Persona	Freq of Use	Action Importance	Segment	Why Target First
ROC / Identity Security Analyst	Daily (worklist)	High — acts on every alert	Loyal Operator	Highest influence on the north-star metric. Triage the risk directly
IAM / IdP Administrator	Weekly (executes fixes)	High — performs remediation	Primary Executor	Second in the chain — must trust the recommendation enough to act without fear
CISO / Security Leader	Monthly (dashboard)	Medium — tracks trend	Executive Consumer	Sponsors renewal. Needs one credible number for board reporting
App / Service Owner	Per-incident	Low — only when their service is flagged	Reluctant Actor	Hardest to convert — needs blast-radius and rollback

				context to act without paralysis
Compliance / Audit Officer	Quarterly (audit)	Medium — evidence trail	Evidence Seeker	Valuable for retention — needs exportable, time-stamped trail

7. Size & Impact Analysis

Target Segment

- Enterprises with ≥1,000 employees running AD, Entra ID, or Okta as primary IdP
- Currently using Qualys VMDR or ETM (existing install base — no greenfield sales required)
- Have ≥1 ROC Analyst or Identity/IAM team actively monitoring identity posture

Assumptions

In the absence of internal Qualys data, the following are derived from public breach data and industry research.

Assumption	Value	Source / Rationale
Qualys enterprise customer base	~3,000 enterprise accounts	Qualys FY24 public earnings — ~10,000 customers, est. ~30% enterprise tier
Avg NHIs per enterprise	~50,000	Industry benchmark: NHIs outnumber humans ~50:1; 1,000 employees → ~50,000 NHIs
% NHIs unmanaged / unattributed	~80% (~40,000 per customer)	Consistent with Silverfort and CyberArk public research
% toxic paths remediable with ETM Identity	~15% of unmanaged NHIs	Conservative: ~6,000 actionable NHIs per customer
Avg breach cost attributable to stolen credentials	\$4.88M per incident	IBM Cost of a Data Breach Report 2024
Breach probability reduction per 100 toxic paths closed	~0.05%	Illustrative and least defensible — see sensitivity below
ETM Identity ACV uplift potential	\$25,000-\$50,000 per customer	Illustrative — NHI scope as add-on module or tier upgrade
Target penetration in Year 1	10% of install base (300 customers)	Conservative adoption given new capability — design-partner model

Impact Calculation

Revenue impact: 300 customers × \$37,500 avg ACV uplift = **\$11.25M incremental ARR in Year 1**

Risk reduction impact: 300 × 6,000 actionable NHIs × 0.05% breach probability reduction × \$4.88M = **~\$44M avoided breach cost across the install base**

Sensitivity

The risk-reduction figure multiplies four assumptions, and is dominated by the breach-probability term. A range is more honest than a point estimate:

Scenario	Prob. reduction / 100 paths	Actionable NHIs	Avoided breach cost
Low	0.01%	3,000	~\$4.4M
Base	0.05%	6,000	~\$44M
High	0.10%	8,000	~\$117M

First assumption to validate: breach-probability reduction per closed path. This cannot be measured directly in a design-partner engagement; the practical proxy is *reduction in reachable Tier-0 assets per remediated chokepoint*, which is observable in-product from day one. The revenue model is more robust — it rests only on penetration and ACV, both standard commercial assumptions.

8. Problem Validation

Initial Hypotheses

- Lack of Visibility** — security teams have no single view of all NHIs across AD, cloud IdPs, and vaults.
- Lack of Ownership** — no mechanism to attribute a responsible human or team to each NHI; the “orphaned account” problem.
- Lack of Prioritization** — a flat export of 40,000 NHIs is operationally useless. Teams need the handful that create real attack paths.
- Lack of a Closed Loop** — even when a risky NHI is flagged, there is no proof the fix worked; no re-validation mechanism.

Validation Approach

Hypotheses tested against: (1) public breach investigation reports (CISA, FBI IC3); (2) industry research (Verizon DBIR 2024, IBM Cost of a Data Breach 2024, CyberArk Global Threat Landscape Report); (3) competitor gap analysis; (4) Qualys public positioning materials (ROCon, Oct 2025).

Limitation to state plainly: this is secondary research only. No primary interviews with ROC analysts were conducted. The first design-partner engagement should prioritize validating the ownership-attribution and blast-radius hypotheses directly.

Research Outcomes

Finding	Valid?	Evidence
80%+ of enterprise breaches involve compromised credentials	✓	Verizon DBIR 2024 — credentials the #1 attack vector for 8 consecutive years
NHIs outnumber human identities by 45–50x	✓	CyberArk 2024 Identity Security Threat Landscape Report
<20% of enterprises have full NHI inventory or ownership mapping	✓	Silverfort 2024 NHI Security Report — 83% of orgs have no NHI discovery process
Teams patch but cannot prove risk went down	✓	Common pattern in SOC tooling; validated in Qualys ETM positioning at ROCon 2025
No IGA/PAM/ITDR tool produces a unified score across vuln + asset + identity	✓	Competitor analysis: SailPoint, Saviynt, CrowdStrike, Silverfort
Lack of Recall — teams forget which NHIs they previously identified	Not confirmed	Teams use spreadsheets; recall is poor but is not the primary bottleneck. Hypothesis dropped

Competitor Research

Capability	SailPoint	Saviynt	CrowdStrike	Silverfort	Qualys ETM Identity
NHI Discovery	–	–	–	✓	✓
Unified Vuln + Asset + Identity Score	–	–	–	–	✓ Only
Confidence-Based Ownership Attribution	–	–	–	–	✓ Only
Attack-Path Graphing to Tier-0	–	–	Partial	Partial	✓
Closed-Loop ROC → ITSM → Re-validate	–	–	–	–	✓ Only
IGA/PAM Signal Ingestion (not replace)	Owens IGA	Owens IGA	–	–	✓ (consumes all)
Access lifecycle depth / certification	✓ Category leader	✓ Strong	–	–	✗ Out of scope
Inline authentication enforcement / blocking	–	–	Partial	✓ Category leader	✗ Read-only by design
Endpoint telemetry depth	–	–	✓ Category leader	–	Partial (via existing agent)

The last three rows are where competitors win. Our position is deliberately an overlay, not a replacement — which is what makes signal ingestion from SailPoint and CyberArk viable rather than adversarial.

Top Takeaways

1. Security teams are intrinsically motivated to manage NHI risk but are paralysed by the absence of a prioritised, ownable worklist.
2. Analysts want to know which NHIs to fix first — a flat export of 40,000 records is the problem, not the solution.
3. App/Service Owners have blast-radius paralysis; they will not rotate a service account without knowing what breaks.
4. No competitor provides unified TruRisk scoring across identity + vulnerability + asset. This is Qualys’s defensible position, and it rests on already owning the asset inventory.
5. Agentic AI is creating NHIs at machine speed — the window for first-mover differentiation is open now.

9. Understanding the Target Audience

Primary Persona — ROC / Identity Security Analyst

Anjali, 29 — Sr. Identity Security Analyst, FinTech, Mumbai

“I get a list of 40,000 service accounts every Monday. I have no idea which ones will get us breached.”

Unmet Goals - Know which of her 40,000 NHIs could get the company breached today - Have a prioritised worklist she can action within her shift — not a spreadsheet - Show her CISO a number that proves risk went down this quarter - Rotate a service account without fearing a 2am production incident

Pain Points - Cannot find who owns 80% of her service accounts; orphaned for years - No tool shows the attack path: *this account* → *CI/CD* → *domain controller* - Existing IGA/ITDR tools show everything as a problem, with no prioritisation - When she fixes something, she has no proof it is actually gone

User Journey Map

Stage	Discovery	Prioritize	Remediate	Verify
Action	Run NHI scan, export 40,000 rows, open spreadsheet	Guess which accounts are dangerous from name patterns	Email App Owner — wait 2 weeks for a response	No idea if the account is actually disabled. Close the ticket anyway
Thoughts	“Where are the accounts that	“Why can’t I see which account	“They’re scared to rotate it —	“Too much effort for no proof.”

	can actually cause a breach?"	reaches our payment database?"	what if it breaks the pipeline?"	
Emotion	Overwhelmed	Confused	Frustrated	Resigned

Pain Point Ranking

Pain Point	Alignment to Goal	Severity	Frequency	Ranking
No unified NHI inventory — accounts scattered across AD, Entra, Okta, vaults, code	High — 100% of NHIs affected	Critical — you can't manage what you can't see	Every scan cycle	High (MVP P0)
No ownership attribution — ~80% of NHIs orphaned	High — remediation impossible without an owner	Critical — every unattributed NHI is unactioned	Every remediation attempt	High (MVP P0)
No prioritisation — 40,000-row flat export is unusable	High — analysts give up	Critical — if everything is urgent, nothing is	Every worklist session	High (MVP P0)
No closed loop — no proof remediation worked	High — CISO cannot report risk reduction	High — erodes trust in the tool over time	Every quarterly review	High-Med
Blast-radius paralysis — App Owners won't act without knowing dependencies	Medium — slows MTTR	High — a rotated account that breaks prod is worse than a risky one	Every remediation execution	High-Med

No Inventory, No Ownership, and No Prioritisation are the three biggest blockers and feed into each other. These form the MVP. Blast-radius paralysis is addressed with supporting context in the ITSM ticket.

10. Descoped

- **Automated credential rotation (v1-v2).** Technically feasible but carries significant blast-radius risk. Without a proven re-validation mechanism (TruConfirm), automated rotation could break production. Descoped to v3 — after the closed loop is proven reliable.
- **LLM-generated NHI risk summaries.** Auto-writing risk narratives is appealing but produces hallucinated context in low-data environments (newly discovered NHIs), risking misrepresentation of severity to a CISO. Descoped; may revisit in v3 with sufficient grounding data.
- **Push-notification remediation alerts to mobile.** Deep-linking into ITSM from a mobile notification is inconsistent across enterprise MDM environments. Risks a fragmented remediation workflow. Descoped for v1.
- **IGA/PAM replacement.** ETM Identity is a risk overlay, not a foundation. Competing with SailPoint or CyberArk at their core function would require 5–10x the scope and would destroy the key differentiator — ingesting their data as a signal.

11. Solution Prioritization

Several approaches were considered against the four bottlenecks: no inventory, no ownership, no prioritisation, no closed loop.

	Unified NHI Discovery + TruRisk Score	Confidence-Based Ownership Attribution	Attack-Path Graph + Closed Loop	Blast-Radius + Rollback Guidance
How it works	Connectors to AD, Entra, Okta, IGA/PAM, and cloud IdPs enumerate all NHIs into a single deduplicated inventory. Each NHI receives an Identity TruRisk score (Exposure × Exploitability × Blast Radius) on the same 1–2000 scale as vulns and assets	Infers a probable owner from four signals: creating account, ITSM ticket history, host naming conventions, recent interactive users. Shows confidence %. One-click confirm/reassign; human validation retrains the model	Graphs lateral-movement paths from a compromised NHI to Tier-0 assets. Ranks toxic paths by hop count. Identifies chokepoints (one fix collapses N paths). Remediation flows ROC → ITSM → App Owner → TruConfirm	Attaches observed dependency evidence and step-by-step rollback instructions to every remediation ticket, so the executor can act without guessing
Benefits	Turns a 40,000-row export into a ranked worklist. Same risk language as vulns — the CISO compares like with like	Removes remediation paralysis. The App Owner receives a specific ticket with a named owner	Proves risk actually went down. The CISO gets a defensible number for the board	Highest trust-per-unit-effort. Directly addresses the reason tickets get ignored
Risks	Connector coverage gaps = blind spots. Must surface coverage % so teams know what they cannot see	Wrong attribution = wrong ticket = lost trust. Confidence scoring plus human-in-the-loop is the mitigation	False-positive paths = noise = ignored. Validation gate before a path is shown as exploitable	Dependency evidence is observational, never complete. Must be framed as observed, not exhaustive

RICE Prioritization

Solution	Reach	Impact	Confidence	Effort	Score
Blast-Radius + Rollback Guidance	5	4	5	2	50
NHI Discovery + TruRisk Scoring	5	5	5	4	31.25 ★ MVP
Confidence-Based Ownership Attribution	5	5	4	4	25
Attack-Path Graph + Closed Loop	4	5	4	5	16

Why the MVP is not the highest RICE score. Blast-Radius guidance ranks highest on effort-adjusted value, but it is a *dependent* capability: there is nothing to compute blast radius *for*, and no ticket to attach it to, until discovery and inventory exist. RICE does not model dependency. Discovery is therefore v0, with Blast-Radius sequenced immediately after as the first value-add on top of it — deliberately ahead of the higher-scoring attribution work, because it is

cheap and it is what converts a generated ticket into an actioned one.

12. User Stories

NHI Unified Inventory

As an Identity Security Analyst, I want a single deduplicated inventory of all NHIs across on-prem and cloud, so that I have no blind spots.

Acceptance Criteria 1. NHIs from AD, Entra ID, Okta, and connected IGA/PAM sources are enumerated within one scan cycle. 2. The same NHI appearing in multiple source systems (e.g. svc-deploy in both AD and Entra) is merged into one record — not duplicated — and the merge confidence is recorded. 3. Where merge confidence falls below threshold, records are flagged as **Possible Duplicate** for analyst review rather than silently merged. 4. Each record shows: type, lifecycle state, entitlements, last-used timestamp, change history, and source systems merged. 5. Inventory is filterable by type (service / machine / workload / agentic-AI), risk level, and ownership status. 6. Discovery coverage % is surfaced prominently, scoped to connected sources — analysts can see what they cannot see. 7. Target: ≥95% NHI enumeration across connected sources within one scan cycle on design-partner tenants.

Ownership Attribution

As an IAM Administrator, I want a probable owner attributed to each NHI with a confidence score, so that I can route remediation without guessing.

Acceptance Criteria 1. Every NHI shows an inferred owner (or **Unattributed**) with a confidence percentage (e.g. “85% — DevOps Team B”). 2. Four signals are used: creating account data, ServiceNow/Jira ticket history, host naming conventions, recent interactive users. 3. Owner can be confirmed or reassigned in one click; the change persists and feeds model retraining. 4. **Unattributed + high-risk** is available as a saved, sortable worklist view, and is the designated triage queue for NHIs where all four signals return null. 5. Bulk owner assignment is supported for ≥100 NHIs in one action. 6. Target: ≥60% attribution at ≥70% confidence after 90 days of human-confirmation feedback, measured against a held-out sample rather than analyst confirmation rate (which is biased toward easy cases).

Identity TruRisk Scoring

As a ROC Analyst, I want each NHI scored with an Identity TruRisk value reflecting real exploitability and blast radius, so that I work the 20 that matter — not the 20,000 that don’t.

Acceptance Criteria 1. Each NHI displays an Identity TruRisk score on the 1–2000 scale with a contributing-factor breakdown (Exposure / Exploitability / Blast Radius). 2. Score incorporates live threat-intelligence context (active targeting of this identity class), not just static configuration. 3. Re-scoring occurs within one cycle of any state change: privilege escalation, credential age change, new threat intel. 4. Analysts can sort and threshold by score to build a personalised worklist. 5. Score uses the same 1–2000 language as vulnerability and asset TruRisk — no new language to learn.

Attack-Path Prioritization

As a ROC Analyst, I want to see the lateral-movement attack paths a compromised NHI enables toward critical assets, so that I fix the chokepoints that collapse many paths at once.

Acceptance Criteria 1. Selecting an NHI renders its outbound attack paths as a directed graph to Tier-0 / crown-jewel assets. 2. Paths are ranked by hop count to the nearest critical asset — shortest route first. 3. Chokepoint NHIs (where one fix collapses N paths) are surfaced and ranked by path-collapse count. 4. Where asset criticality tiering is absent or stale in the customer environment, the UI states this explicitly rather than defaulting silently. 5. The graph label makes clear: *Remediation triggered via ITSM ticket — not automated blocking in v1*. 6. Graph computation for a 50,000-NHI tenant completes within the defined latency budget.

ROC → ITSM Closed Loop (v1-v2)

As a CISO, I want remediation to flow through ServiceNow/Jira with verified before/after risk, so that I can show the board that identity exposure actually went down.

Acceptance Criteria 1. Clicking **Remediate** on a flagged NHI or chokepoint auto-generates an ITSM ticket containing: owner name, observed-dependency note, rollback guidance, and current TruRisk score. 2. The ticket is assigned to the attributed owner automatically. 3. Identity TruRisk score updates on confirmed closure. 4. A QoQ trend view shows aggregate NHI TruRisk score over time, sliceable by business unit or asset classification. 5. An exportable, time-stamped audit trail records every state change for compliance purposes.

Version note: TruConfirm re-validation on ticket closure is **v2 scope**, not v1. Until it ships, ticket closure updates the score but is labelled *Unverified* in the UI. Claiming verification before the re-validation engine exists would undermine the one thing the closed loop is for.

Blast-Radius + Rollback Guidance

As an App/Service Owner, I want to know what depends on this service account before I rotate it, so that I can act without fearing a 2am production incident.

Acceptance Criteria 1. Every ITSM ticket generated by ETM Identity includes an **Observed Dependency Note**: hosts and services that authenticated using this NHI within the observation window, with the window length stated. 2. The note is explicitly framed as *observed, not exhaustive* — credentials hardcoded in images, config files, or infrequently-run jobs may not appear. 3. Rollback guidance is included: step-by-step instructions to reverse the change if it causes an incident. 4. A **Staged Rotation** option (dev → stage → prod) is offered where dependency analysis supports it. 5. The App Owner can confirm or reject the dependency list; their input improves the dependency model.

13. Risk & Mitigation

Risk	Mitigation
------	------------

Value Risk: Wrong owner attribution → wrong ticket → analyst loses trust	Confidence score shown on every attribution. Human confirm/reassign loop retrains the model. Analysts can override. Attribution quality tracked against a held-out sample, not confirmation rate
Value Risk: Attribution signals all return null for genuine orphans — the highest-value population	Explicit Unattributed + High-Risk triage queue with a manual assignment workflow. The product does not guess when it has no signal; guessing is worse than admitting ignorance
Usability Risk: Attack-path graph is noisy — too many paths, analysts give up	Validation gate: a path is shown as <i>exploitable</i> only after automated re-validation. Chokepoint view collapses complexity. Filters by hop count and risk score
Feasibility Risk: Connector gaps leave NHIs undiscovered while analysts believe coverage is complete	Coverage % surfaced prominently, scoped to connected sources. “Known unknown” flagging for connectors returning partial data. Never imply 100% coverage
Feasibility Risk: Deduplication across sources without a shared key produces false merges or false splits	Merge-confidence scoring; sub-threshold matches surface as Possible Duplicate for analyst adjudication rather than silent merge. Dedup precision tracked as a launch-gating quality metric
Feasibility Risk: Dependency data is incomplete — a rotation breaks production despite a clean blast-radius note	Framed as observed dependencies with a stated window. Staged rotation offered by default. Rollback guidance mandatory on every ticket
Scalability Risk: NHI state-change volume (40M+ events per cycle) cannot be human-reviewed	Automated triage pipeline surfaces only threshold-crossing changes to the worklist. Human review reserved for chokepoints and failed re-validations
Trust Risk: CISO sees the TruRisk score drop, then a breach occurs anyway, and questions the score’s validity	TruRisk is a probability-weighted indicator, not a guarantee. In-UI framing: <i>this score reflects known exploitability; unknown vectors are not captured</i> . Transparency over false precision
Integration Risk: ITSM API failure breaks the remediation loop	Graceful degradation — recommendations stay visible with copy-to-clipboard for manual entry. Alert to platform team if the ITSM API is down >5 min
Adoption Risk: App Owners ignore ITSM tickets; the dependency note is not convincing enough	A/B test ticket with vs. without staged-rotation option. Track acceptance rate by persona. If <30% acceptance in 60 days, escalate to PM for ticket redesign
Commercial Risk: The identity team is a different buyer from the VM team that already owns Qualys, and controls the IdP permissions we need	Design-partner selection prioritises accounts with a unified security org. Read-only scope and no-write architecture used to shorten the identity team’s security review. Permission requirements documented pre-sales

14. Data & Logic Changes

Algorithm / Logic

- **Identity TruRisk calculation.** Per-NHI score = $\text{Exposure_weight} \times \text{Exploitability_score} \times \text{Blast_Radius_multiplier}$, normalised to the 1–2000 scale. Recalculated within one scan cycle of any state change. Weighted recency: $0.6 \times \text{current_state_score} + 0.4 \times \text{historical_avg_score}$.
- **Ownership attribution model.** Confidence = weighted sum of four signal scores (creating account 0.30, ticket history 0.30, naming convention 0.20, recent interactive users 0.20). Human confirmation events update signal weights via Bayesian update. Where all four signals are null, confidence is 0 and the NHI routes to the manual triage queue.
- **Attack-path rank.** $\text{weighted_hop_count} \times \text{asset_criticality_multiplier}$. Chokepoint score = number of paths passing through this NHI × average path rank.
- **Deduplication merge confidence.** Weighted match across display name, SID/object-ID linkage where available, credential fingerprint, and authentication source overlap. Below threshold → flagged, not merged.
- **TruConfirm re-validation logic (v2).** On ticket closure, re-scan the NHI’s entitlements and attack-path graph. Validation runs only against data below a freshness threshold, to avoid reopening correctly-closed tickets on stale state. If the path still exists → reopen automatically with *Re-validation Failed*.

Schema Changes

Field Name	Data Type	Nullable	Source	Description
nhi_id	UUID	NOT NULL	Discovery Agent	Primary key. Stable across scan cycles — not regenerated on rescan
nhi_display_name	VARCHAR(255)	NOT NULL	IdP Source	Human-readable name from originating IdP, preserved as-is (e.g. svc-deploy)
nhi_type	ENUM	NOT NULL	Discovery Agent	service_account \\ machine_identity \\ api_key \\ workload_identity \\ agentic_ai \\ other
nhi_lifecycle_state	ENUM	NOT NULL	Discovery Agent	active \\ dormant \\ disabled \\ orphaned \\ pending_review . Drives the Exposure component
nhi_source_systems	VARCHAR(500)	NOT NULL	Discovery Agent	Comma-separated source systems (e.g. AD, EntraID, Okta)
nhi_merge_confidence_pct	DECIMAL(4,1)	NULLABLE	Dedup Engine	Confidence that multi-source records represent one identity. Below threshold → surfaced as Possible Duplicate

nhi_last_used_datetime	TIMESTAMP	NULLABLE	IdP / Agent	UTC timestamp of last observed authentication. NULL if none in observation window
nhi_identity_trurisk_score	DECIMAL(6,2)	NULLABLE	ETM Engine	Per-NHI score on the 1–2000 scale. NULL until first scoring cycle
nhi_exposure_score	DECIMAL(4,2)	NULLABLE	ETM Engine	0–10: missing MFA, stale credentials, excessive privilege, dormant-but-enabled, shared credential
nhi_exploitability_score	DECIMAL(4,2)	NULLABLE	Threat Intel	0–10: active targeting of this NHI class, known techniques (Kerberoasting, ASREP-Roasting), campaigns in last 30 days
nhi_blast_radius_score	DECIMAL(4,2)	NULLABLE	ETM Engine	0–10: $\text{asset_criticality_tier} \times \text{privileged_group_membership} \times \text{inverse}(\text{hop_count_to_tier0})$
nhi_attack_path_count	INTEGER	DEFAULT 0	Graph Engine	Active paths through this NHI to Tier-0 assets. Decrement on verified remediation
nhi_is_chokepoint	BOOLEAN	DEFAULT FALSE	Graph Engine	TRUE when $\text{nhi_attack_path_count} \geq 3$ distinct paths to critical assets. Surfaced at top of worklist
nhi_owner_attributed	VARCHAR(255)	NULLABLE	Attribution Model	Inferred owner team/user. NULL when no signal meets threshold (default 40%); shown as Unattributed
nhi_owner_confidence_pct	DECIMAL(4,1)	NULLABLE	Attribution Model	0.0–100.0. Weighted sum of four signals. Updates after each human confirmation
nhi_owner_confirmed_by	VARCHAR(255)	NULLABLE	Human Confirm Event	User principal who last confirmed or reassigned ownership. NULL if never confirmed. Retained for audit
nhi_attribution_signals	VARCHAR(500)	NULLABLE	Attribution Model	JSON map of four signal scores: <code>creating_account</code> , <code>ticket_history</code> , <code>naming_convention</code> , <code>recent_interactive_users</code>
nhi_itsm_ticket_id	VARCHAR(100)	NULLABLE	ITSM Integration	External ServiceNow / Jira ticket ID. NULL if no remediation ticket created
nhi_truconfirm_status	ENUM	DEFAULT not_triggered	TruConfirm Engine	<code>not_triggered</code> \ <code>pending</code> \ <code>passed</code> \ <code>failed</code> . <code>failed</code> auto-reopens the ITSM ticket with reason
nhi_remediation_action	VARCHAR(200)	NULLABLE	ITSM Closure Event	<code>credential_rotated</code> \ <code>account_disabled</code> \ <code>privilege_reduced</code> \ <code>mfa_enforced</code>
nhi_privileged_group_member	BOOLEAN	DEFAULT FALSE	Discovery Agent	TRUE if the NHI holds Domain Admins, Enterprise Admins, or Global Administrator. Auto-elevates Blast Radius
nhi_mfa_status	ENUM	NULLABLE	IdP Source	<code>enrolled</code> \ <code>not_enrolled</code> \ <code>not_applicable</code> \ <code>unknown</code> . <code>not_applicable</code> where MFA is architecturally unsupported
nhi_credential_age_days	INTEGER	NULLABLE	IdP Source	Days since last rotation, from IdP metadata. NULL when rotation date is unavailable
nhi_compliance_tags	VARCHAR(300)	NULLABLE	Compliance Engine	NIS2 \ NERC_CIP \ IEC_62443 \ SOC2 \ PCI_DSS. Drives compliance export and scoring adjustments

15. Data Instrumentation

Key Metric	Event Name	Variables Tracked
Aggregate NHI TruRisk Score (North Star)	nhi_score_calculated	nhi_id, nhi_identity_trurisk_score, nhi_exposure_score, nhi_exploitability_score, nhi_blast_radius_score, score_version, scan_cycle_id, calculation_duration_ms
NHI Discovery Coverage %	nhi_scan_completed	scan_cycle_id, source_system, nhi_count_discovered, nhi_count_deduplicated, coverage_pct_connected_sources, scan_duration_ms, connector_version
Deduplication Quality	nhi_dedup_evaluated	nhi_id, candidate_ids, merge_confidence_pct, merge_decision, flagged_for_review
% NHIs with Attributed Owner	nhi_owner_attributed_event	nhi_id, owner_attributed, owner_confidence_pct, attribution_signals_json, is_new_attribution, previous_owner, all_signals_null
Attribution Model Accuracy	nhi_owner_confirmed / nhi_owner_reassigned	nhi_id, previous_owner, new_owner, confirmed_by_user_id, confirmation_datetime, confidence_delta, in_holdout_sample
# Open Toxic Attack Paths	attack_path_graph_updated	nhi_id, path_id, path_hop_count, target_asset_id, target_asset_tier, is_chokepoint, path_risk_score, graph_computation_ms
MTTR — flagged	itsm_ticket_created	nhi_id, ticket_id, ticket_system, owner_assigned, dependency_note_included, remediation_type, ticket_created_datetime
MTTR — closed	itsm_ticket_closed	nhi_id, ticket_id, ticket_closed_datetime, time_to_close_hours, remediation_action, resolution_notes_length
TruConfirm Pass Rate	truconfirm_revalidation_run	nhi_id, ticket_id, revalidation_status, attack_path_still_exists, score_delta, data_freshness_minutes, revalidation_datetime
% Recommendations → Tickets	remediation_recommended	nhi_id, recommendation_type, recommendation_datetime, recommendation_rank_at_time, analyst_user_id
Ticket Abandonment (Failure Metric)	itsm_ticket_abandoned	nhi_id, ticket_id, assigned_owner_persona, time_in_open_state_hours, abandonment_reason, escalation_triggered

16. System Design

Architecture: ETM Identity operates as an intelligence overlay — consuming signals from identity sources and producing a unified risk picture. It does **not** write to AD / Entra / Okta; it reads and enriches. This read-only posture is both a security-review advantage and the reason signal ingestion from SailPoint and CyberArk is viable rather than competitive.

Components: 1. Discovery Connectors → 2. Deduplication & Normalisation Engine → 3. TruRisk Scoring Pipeline → 4. Ownership Attribution Model → 5. Attack-Path Graph Engine → 6. ROC Worklist UI → 7. ITSM Integration Layer → 8. TruConfirm Re-validation (v2) → 9. Audit Trail DB

Scenario-Based Tests (Edge Cases)

ID	Objective & Precondition	Test Input	Acceptable Outcome	Failure Outcome
1	Deduplication — same NHI in multiple sources. svc-deploy exists in both AD and Entra ID	Discovery scan with both connectors active	One merged record, Sources: AD, EntraID, merge confidence recorded. No duplicate entries	Two separate records — triggers a dedup pipeline alert to engineering
2	Deduplication — false-match risk. Two unrelated accounts share the naming convention svc-deploy in different domains	Discovery scan across both domains	Merge confidence falls below threshold; both surface as Possible Duplicate for analyst adjudication	Silent merge — a Tier-0 attack path is attributed to the wrong identity
3	Ownership attribution — no signal matches. NHI has no ticket history, no naming match, no creating-account data	Orphaned API key created 3 years ago by a deleted user	Shown as Unattributed , confidence 0%, routed to the manual triage queue with a prompt to assign	System assigns a stale or inferred owner — triggers a false-attribution alert
4	Attack-path graph — cyclic dependency. NHI-A has access to NHI-B, which has access back to NHI-A	Graph engine processes circular entitlement chain	Cycle detected and broken at the lowest-risk node. Graph renders without infinite loop	Graph engine hangs or crashes — engineering incident
5	Attack path — missing asset tiering. Customer tenant has	Graph engine runs against untiered asset inventory	UI states that asset criticality is unavailable and ranks by hop	Graph silently assumes a default tier — produces

	no Tier-0 classification applied		count only. No implied criticality	misleading path rankings
6	TruConfirm re-validation after rotation (v2). ITSM ticket closed, rotation of <code>svc-deploy</code> claimed	Ticket closure event triggers re-validation scan	If entitlements unchanged → ticket reopened as <i>Re-validation Failed</i> . If rotated → score updates, path count drops	Re-validation runs but the result is not written back — analyst gets no feedback
7	TruConfirm — stale source data. IdP data is 6 hours old at time of re-validation	Closure event fires before next IdP sync	Validation defers until data is within the freshness threshold; ticket held in <i>Pending Verification</i>	Correctly-closed ticket is reopened on stale state — analyst trust lost
8	ITSM API down during remediation. Analyst clicks Remediate on a high-risk NHI	ServiceNow API returns 503	Graceful degradation: <i>ITSM unavailable — copy remediation details</i> . NHI held in <i>Pending Remediation</i> . Platform team alerted	UI crashes or shows a blank state — analyst loses remediation context
9	Connector returns partial data. Entra connector times out mid-scan	Entra returns 60% of expected NHI count vs. baseline	Coverage % drops and a warning surfaces: <i>Entra ID scan incomplete — 40% of expected NHIs not returned</i>	System shows full coverage — analyst believes the inventory is complete when it is not

17. Launch Readiness

Checklist for **v0 launch (Discovery & Inventory)** — target Q3 2026. All statuses below are proposed for a hypothetical execution plan.

#	Milestone	Checklist	Timeline
1	Design Sign-Off (v0)	Med-fidelity wireframes for NHI inventory list view · High-fidelity mockups for Identity Record Card · Design review with a design-partner ROC Analyst	Q2 W1–W2
2	PRD Sign-Off (v0 MVP)	Problem validation complete · User stories with acceptance criteria · Dev and analytics queries resolved	Q2 W2–W3
3	Connector Development (AD, Entra, Okta)	AD connector technical spec sign-off · Entra ID API permission sign-off · Okta connector sprint 1 · Integration tests with dedup engine	Q2 W3 – Q3 W2
4	Deduplication Engine	Merge-confidence model validated on design-partner data · Possible-Duplicate review workflow · Precision/recall gate before GA	Q2 W4 – Q3 W2
5	TruRisk Scoring Pipeline	Scoring formula validated with Threat Research · Re-scoring trigger unit tests · Integration with existing TruRisk normalisation layer	Q2 W4 – Q3 W2
6	QA Testing	Scenario tests 1–9 · Connector failure and partial-data tests · Performance tests under load · Coverage % accuracy test	Q3 W1–W3
7	Dogfooding (Internal UAT)	Alpha sign-off with internal ROC team · Beta with 2 design-partner customers · A/B test — ranked worklist vs. flat list	Q3 W2–W4
8	KPI Dashboard	New metrics added to ROC dashboard · Data pipeline integrity test · Audit trail export verified for Compliance persona	Q3 W3–W4
9	Launch Communication	In-app banner and email for ETM Identity customers · Sales enablement deck · Product page update	Q3 W4

18. Future Iterations

Goal for v2–v3: close the remediation loop completely (v2), then automate rotation with guardrails (v3).

User Story	High-Level Idea	Version	Priority
As a ROC Analyst, I want TruConfirm to automatically re-validate that a remediated path is actually gone, so that I can close tickets with confidence.	On ticket closure, re-scan the NHI's entitlements and attack-path graph against fresh source data. If the path persists → auto-reopen as <i>Re-validation Failed</i> . CISO sees Paths Closed (Verified) , not just tickets closed	v2	P1

As a CISO, I want a single QoQ Identity TruRisk trend for my organisation, so that I can report to the board that identity exposure is decreasing.	Aggregate NHI TruRisk tracked QoQ, sliceable by business unit, asset classification, and NHI type. Exportable as a board-ready PDF with before/after context per remediation cycle	v2	P1
As an App Owner, I want a staged rotation option so that I can rotate a service account in dev before I touch production.	Environment tiers detected from asset tags. Staged wizard: rotate in dev → monitor 48h → stage → prod. Blast radius recalculated after each stage	v2	P1
As an Identity Security Analyst, I want text search and a one-line risk summary per NHI, so that I can process the workload faster.	Full-text filter across all NHI metadata fields. Deterministic template-generated one-line summary (e.g. "Stale service account with domain-admin path to 3 Tier-0 assets — last used 180 days ago"), generated from structured fields rather than free-form generation	v2	P2
As a ROC Analyst, I want automated rotation for NHIs with low blast radius, so that I don't spend analyst time on routine low-risk rotations.	Identify NHIs below a configurable blast-radius threshold (e.g. no Tier-0 dependencies). Automated rotation via CyberArk/Delinea API on a defined schedule. Human approval required for medium blast radius	v3	P1
As an analyst, I want to be notified when a previously-remediated NHI resurfaces as high-risk, so that I can re-open remediation before the exposure is re-exploited.	When a TruConfirm-verified closed NHI re-enters a high-risk state (e.g. privilege re-escalation), the original remediating analyst is alerted and the NHI is re-surfaced at the top of the workload	v3	P2
As an analyst using a non-English interface, I want NHI risk summaries in my local language, so that I have a native experience.	Risk summaries and remediation notes available in English, German, Japanese, Spanish, French via the existing Qualys localisation pipeline	v3	P3

19. Key Feasibility Uncertainties

Stated explicitly, because the assumptions most likely to be wrong are the ones worth naming before a reviewer finds them.

- Ownership attribution on true orphans.** All four attribution signals degrade precisely where the need is greatest — a three-year-old API key created by a deleted user returns null on every signal. The 60% target is achievable across the full population but will skew heavily toward recently-created, well-governed NHIs. *First experiment:* measure per-signal hit rate on design-partner data segmented by NHI age, before committing to a public accuracy figure.
- Dependency completeness for blast radius.** Credentials hardcoded in container images, config files, or quarterly batch jobs are invisible to authentication telemetry. The product can offer observed dependencies over a window, never a complete list. *Mitigation is product framing, not engineering:* label it observed, state the window, mandate rollback guidance, default to staged rotation.
- Cross-source deduplication without a shared key.** Everything downstream — scoring, attribution, path counts — inherits dedup errors. This is the single highest-leverage correctness risk in v0 and is why merge confidence is a first-class field rather than an implementation detail.

Portfolio Disclaimer: This document is an unsolicited PRD written by Kushal Zambare based solely on public Qualys ETM Identity materials (ROCon Houston, October 2025; Qualys product documentation). It is not affiliated with or endorsed by Qualys, Inc. All sizing numbers are illustrative assumptions, not internal Qualys data.